PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité des objets connectés (ANSSI)

03-1010 ANSSI - Recommandations relatives à la sécurité des objets connectés — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les objets connectés présentent des risques d'effets physiques et d'effets systémiques de masse.
2. Le guide propose 63 recommandations techniques génériques basées sur une analyse de sécurité initiale.
3. La protection du dispositif repose sur une chaîne de démarrage sécurisée et l'interdiction du retour à une version antérieure du micrologiciel.

Spécificités des objets connectés

Notion	À retenir
Une grande diversité	Matériels divers (**pacemaker**, **système industriel**, **domotique**). Le **capteur** mesure, l'**actionneur** agit sur le monde physique : **effets physiques** et **effets systémiques** (déploiements massifs). Menaces classiques aggravées par **faibles ressources** et **systèmes non administrés**.
La démarche du guide	Départ : **analyse de sécurité** (scénarios d'attaque, biens à protéger, fonctions de sécurité). Le guide propose **63 recommandations techniques génériques**.

Objectifs de sécurité

Notion	À retenir
Environnement hostile	Protéger contre les **menaces extérieures** et celles des **propres constituants**. Communications **authentifiées** et **limitées au besoin**.
Cycle de vie	Confiance reposant sur des **secrets protégés et gérés** sur tout le cycle. **Maintien en condition de sécurité** prévu dès la conception.
Fonctions de sécurité	Composants **éprouvés** et **vulnérabilités suivies**. Méthode de développement **intégrant la sécurité** pour réduire le coût du maintien.
Données sensibles	Assurer **confidentialité** et **intégrité** (stockage et transport). Appliquer une **politique de gestion** des données exportées vers un système distant.

Architecture et développement

Notion	À retenir
Données et infrastructure distante	Limiter la collecte, protéger les données, encadrer leur présence en infrastructure distante et minimiser ses droits sur les dispositifs. **Protéger en intégrité les commandes** et réaliser les tâches sensibles en environnement adapté.
Composants et tests	Employer des **composants éprouvés**, maintenir en condition de sécurité les **composants tiers**, **tester** et pratiquer le **fuzzing**.

Gestion des clés et Authentification

Notion	À retenir
Gestion des clés	Protéger les **secrets** (surtout les **secrets maîtres**), utiliser des **secrets symétriques dérivés**, affecter les clés de manière maîtrisée, attribuer un **rôle unique** par clé publique, limiter la **durée de vie** et prévoir la **révocation**.
Authentification	Exiger une authentification pour les **actions sensibles**, utiliser des **secrets uniques** par dispositif et des **protocoles à l'état de l'art**, stocker des **empreintes** (pas les mots de passe) et limiter le **nombre d'essais**.

Synthèse de la protection du dispositif

Notion	À retenir
Données et attaque	Protéger les **communications** et les **données locales** (volatiles et non volatiles) ; minimiser la **surface d'attaque**.
Démarrage et mises à jour	Chaîne de **démarrage sécurisée** ; mises à jour du **micrologiciel** authentifiées, versionnées et vérifiées localement. **Interdire** le retour à une version plus ancienne.
Compartimentation et code	Compartimenter **applications**, **services**, **utilisateurs** (multi-utilisateurs) et **processus**. Code durci via **analyse statique** et outils à jour.
Journalisation	Définir **durée de rétention** et **droits d'accès** ; journaux en **lecture seule** et **déportés**.
Sécurité matérielle	Protéger l'accès aux **composants** et leurs communications ; gérer les **perturbations** et **canaux auxiliaires** ; utiliser un **environnement dédié**.

Résumé Réseau, Radio et Support

Notion	À retenir
Réseau	Traiter avec méfiance les **requêtes d'origine inconnue**, minimiser les **services exposés**, se prémunir contre les **attaques par réflexion UDP** et protéger les **données en transport**.
Radio	Prendre en compte le **brouillage des canaux radio**, le risque de **traçage par identifiants radio persistants** et encadrer le **déblocage d'actions sensibles**.
Surveillance et support	Surveiller le système et ses **impacts systémiques**. Publier un **point de contact**, répondre aux **signalements**, s'engager sur une **durée de support** (avec maintenance au-delà) et définir une **politique de gestion des vulnérabilités**.

Pièges et confusions

- ⚠ Croire que les objets connectés ne présentent que des menaces classiques.
- ⚠ Utiliser des secrets d'authentification partagés entre tous les dispositifs au lieu de secrets uniques.
- ⚠ Autoriser par défaut l'installation d'une version logicielle plus ancienne que celle déjà déployée.
- ⚠ Penser que l'analyse de sécurité est une lecture unique et non le point de départ.
- ⚠ Oublier que le fabricant doit s'engager sur une durée de support et un point de contact pour les vulnérabilités.

Sigles et définitions

Dispositif connecté	équipement disposant d'une liaison numérique avec son environnement
Système connecté	ensemble de dispositifs connectés qui dialoguent entre eux
Secret maître	secret à partir duquel d'autres clés sont dérivées
Mécanisme anti-rollback	interdit par défaut l'installation d'une version logicielle plus ancienne
Fuzzing	technique de test qui injecte des entrées aléatoires ou malformées
Compartimentation	isole les applications, services, utilisateurs ou processus les uns des autres
Canal auxiliaire	fuite d'information par des grandeurs physiques
MCS	ensemble des actions qui conservent le niveau de sécurité d'un produit pendant sa durée de vie

Auto-test

1. Qu'est-ce qu'un actionneur ?
2. Que vérifie la chaîne de démarrage sécurisée ?
3. Quel protocole est souvent utilisé pour l'attaque par réflexion ?
4. Que doit-on stocker à la place des mots de passe pour l'authentification ?
5. Quel est l'objectif de la compartimentation ?

Réponses : **1.** Il agit sur le monde physique · **2.** L'authenticité du logiciel chargé à chaque étape · **3.** UDP · **4.** Des empreintes · **5.** Limiter les effets d'une compromission

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.